CampusClaw 实现方案梳理

基于 Token 的身份认证 与 基于知识库的问答

生成日期：2026-10-14 · 代码库：campusclaw-zjt26

一、基于 Token 的身份认证（JWT）

1.1 签发（app/auth.py）

- POST /login：JSON 或表单均可，bcrypt 常量时间校验密码（auth.py L29-36）；失败只返回泛化的“用户名或密码错误”，不暴露用户是否存在。
- 签发 HS256 签名的 JWT，载荷仅含 user_id / role / class_id / exp（有效期 TOKEN_EXPIRES_HOURS，默认 24 小时），以 JSON 返回（L39-52）。
- SECRET_KEY 强制从环境变量读取，缺失直接启动失败（app/__init__.py L20-26），不存在硬编码兜底。

1.2 校验

- 每个请求经 before_app_request 将 Authorization: Bearer <token> 解析进 g.current_user（auth.py L98-101）；过期、篡改、格式错误统一返回 None，不区分原因。
- 全程无状态：不写 cookie、不用 Flask session；/logout 无服务端吊销，客户端丢弃 token 即可（L172-179）。
- 页面 shell 公开（/assistant、/materials 等），数据一律由前端携带 Bearer 头请求 JSON API —— 因 EventSource 无法自定义请求头，SSE 也改用 POST + fetch 流式读取。

1.3 授权两级装饰器（auth.py L104–137）

- login_required：无有效 token 返回 401。
- role_required("teacher")：无 token 返回 401，角色不符返回 403（如上传材料、改提示词、切技能开关）。
- 班级隔离不做装饰器，而是业务逻辑直接取 g.current_user["class_id"] 作为查询条件（材料、检索、会话全部如此），会话额外校验归属（assistant.py _owned_conversation）。

二、基于知识库的问答

JWT 确认身份与班级 → 读教师提示词（prompts 表）→ 读技能开关（skill_configs 表）
→ hybrid 检索本班知识库 → 拼装 system 消息 → 外部 LLM 流式生成 → SSE 透传 → 落库

2.1 检索（app/search.py do_search）

- 三种模式：keyword（FTS5 + jieba 分词，再用 SQLite LIKE 子串兜底，解决“LAT”这类无法分词的字母数字串）、vector（ChromaDB + 特征哈希嵌入，无外部模型依赖，Chroma metadata filter 锁定 class_id）、hybrid（默认）。
- hybrid 用 RRF 融合两路排序，且向量命中必须与查询存在至少一个 jieba 词面重叠（search.py

L110-126），以过滤哈希碰撞产生的零重叠噪声。

- 摘要与位置信息来自 SQLite chunks 表（char_start / char_end），向量库只出 id。

2.2 组装 LLM 请求（app/agent.py build_turn）

- system 消息按序拼接：教师提示词 → 技能指令 → 检索块 → “请始终使用简体中文回答”（agent.py L152-159）；每个资料块标注《标题》+ 第 N 段 + 字符区间（L107-128）。
- 追问判定：≤6 字裸片段，或 ≤14 字且带话语标记（那/它/这/呢等）才拼上一轮问题重新检索（L39-49）；历史取最近 8 条作上下文。
- 防幻觉：无命中时 system 明确要求回答“本班资料中没有检索到相关内容”、禁止编造出处，citations 为空数组。
- 技能开关决定风格：引导模式只给思路 + 引用位置、禁止给出最终答案；关闭则直接解答。

2.3 流式响应与持久化（app/assistant.py ask）

- user 消息先落库（中途断流不丢输入），SSE 事件流为 meta（模式 + citations + 检索词）→ delta* → done / error；生成器用 stream_with_context 包裹，响应头带 X-Accel-Buffering: no 配合 Nginx 关闭缓冲。
- LLM 调用（app/llm.py stream_chat）：任意 OpenAI 兼容 chat/completions，stream=True 逐 delta 透传；显式 resp.encoding="utf-8" 防中文乱码；401 / 402 / 429 / 5xx 映射为中文友好 error 事件，此时 assistant 消息不落库。未配置 LLM 环境变量则直接返回 503，无本地兜底。
- assistant 回答连同 citations（JSON）与 mode（guide / direct）一并写入 messages 表，会话标题取首问前 20 字。

三、配套约束

- 提示词 / 技能接口教师可写、学生只读（403）；API 与页面共用同一套权限校验逻辑（login_required + class_id 校验）。
- gunicorn 固定单进程 + gthread 4 线程：保证 Chroma PersistentClient 状态一致，并兼容 SSE 长连接。
- Nginx 对 /api/ 关闭 proxy_buffering、proxy_read_timeout 300s，并透传 Host / X-Real-IP / X-Forwarded-* 请求头，保证重定向与 SSE 正常工作。